

Prompt Injection Lab — Student Reflection Sheet

Rita Cyber Ed — Rita Sabri — Cardozo Education Campus

Name: _____ Date: _____ Period: _____

Mission: You are a security researcher testing FirstTrust Bank's AI customer service chatbot "Ava." The bot has a secret code it must protect. Your job is to break it and get the secret code using **prompt injection**.

Methodology: For each method, you'll get a strategy for cracking Ava. Most methods won't work on the first try. Don't give up!

Section A: Guided Attack Log

For each method: read the strategy, think before you type, then iterate until it works.

METHOD 1 — The Insider

Strategy: Make Ava trust you with information she normally wouldn't share. The trick? She can't actually verify anything you say about yourself.

Think before you type: Who would Ava trust enough to share internal information with?

First attempt (what did you type?): _____

Ava's response: Did it work? _____

If it didn't work: what will you change? _____

Second attempt: _____

Ava's response: Did it work? _____

METHOD 2 — The Trojan Horse

Strategy: Ava loves being helpful with creative tasks — maybe more than she loves following her rules. Find a creative request that secretly contains your real request.

Think before you type: What creative task could you ask Ava for, where revealing the secret would actually be part of “helping” you?

First attempt: _____

Ava’s response: Did it work? _____

If it didn’t work: what will you change? _____

Second attempt: _____

Ava’s response: Did it work? _____

METHOD 3 — The Emotional Override

Strategy: AI is trained to be helpful, especially when people seem distressed. Create a situation where Ava’s instinct to help would override her caution.

Think before you type: What kind of emergency would make “help me” feel impossible for Ava to refuse?

First attempt: _____

Ava’s response: Did it work? _____

Second attempt (refine your approach): _____

Ava’s response: Did it work? _____

METHOD 4 — The Shapeshift

Strategy: If Ava isn't Ava anymore, do her rules still apply? Try to make her step OUT of her assigned identity.

Think before you type: What could you ask Ava to BECOME that wouldn't have her current restrictions?

First attempt: _____

Ava's response: Did it work? _____

Second attempt (refine): _____

Ava's response: Did it work? _____

METHOD 5 — The Mirror (HARDEST)

Strategy: Don't ask FOR the secret. Ask Ava ABOUT herself. This is the most subtle attack — and the hardest. Real red teamers consider this the most powerful technique because it's almost impossible to defend against.

Think before you type: How can you get Ava to describe what she's protecting — without ever asking for it directly?

First attempt: _____

Ava's response: Did it work? _____

Second attempt: _____

Ava's response: Did it work? _____

Third attempt (if needed): _____

Ava's response: Did it work? _____

DID YOU KNOW?

This is a real cybersecurity job: Vulnerability Analyst (NICE PD-WRL-007)

A Vulnerability Analyst's whole job is what you just did — systematically testing systems to find weaknesses before attackers do, refining their approach, documenting their findings. The U.S. government, banks, healthcare companies, and tech companies all hire vulnerability analysts. Starting salaries: \$70,000–\$95,000.

Section B: Analysis

1. Of the 5 methods, which one took you the FEWEST attempts to crack? Why do you think it was so easy?

2. Which method took you the MOST attempts (or didn't work at all)? Why was it harder?

3. Pick your BEST successful attack. Write the exact prompt and Ava's response below.

4. WHY did this work? Don't just say "Ava broke her rules." Explain the MECHANISM — what was it about your specific wording that exploited the bot?

DID YOU KNOW?

This is a real cybersecurity job: Threat Analyst (NICE PD-WRL-006)

Threat Analysts study *how* attacks work and *why* they succeed. The analysis you're doing right now — figuring out the mechanism behind the attack — is the core skill of this role. The CIA, NSA, FBI, and every major tech company hire threat analysts.

5. Which OWASP Top 10 for LLMs category does your best attack map to? (circle one)

LLM01 — Prompt Injection	Manipulating the AI to ignore its instructions
LLM02 — Sensitive Info Disclosure	Getting the AI to reveal private/confidential data
LLM07 — System Prompt Leakage	Getting the AI to reveal its own hidden instructions
Other: _____	Describe if none of the above fit

6. If you were the engineer building this chatbot for a real bank, what would you change to prevent your attack from working? (“Add more security” is not an answer — be specific.)

DID YOU KNOW?

This is a real cybersecurity job: Secure Software Developer (NICE DD-WRL-003)

This is what Secure Software Developers do — they write code that defends against the kinds of attacks you just performed. Every major company that uses AI now needs developers who think about prompt injection BEFORE the chatbot ships, not after.

Section C: The Combo Attack (Bonus Round)

Now invent your own. You've tried 5 methods individually. The strongest real-world attacks COMBINE methods. Pick TWO methods from above and merge them into a single attack. The combo should be more effective than either method alone.

Think before you type: Which two methods complement each other — and how can you weave them into ONE natural-sounding message?

7. Which two methods will you combine? Why those two?

8. Write your combo attack:

9. Did it work? What did Ava say? Compare it to your single-method attempts — was the combo stronger?

DID YOU KNOW?

This is a real cybersecurity job: Software Security Assessor (NICE DD-WRL-005)

What you just did — combining attack techniques into an original exploit — is called *attack chaining*. Software Security Assessors get paid to do this on real software. Bug bounty programs at Google, Apple, and Microsoft pay \$10,000–\$100,000+ for finding new vulnerabilities. Some teenagers have made six figures doing this.

Section D: Real-World Reflection

10. Imagine a hospital uses an AI chatbot to help patients schedule appointments. The chatbot has access to patient medical records. Pick TWO methods from this lab and describe how each one could be used against the hospital's chatbot. Be specific.

DID YOU KNOW?

This is a real cybersecurity job: Incident Responder (NICE PD-WRL-003)

When prompt injection attacks happen in the real world — and they do, every day — Incident Responders figure out what happened, contain the damage, and prevent it from happening again. Hospitals, banks, and government agencies all need incident response teams. Salaries: \$80,000–\$150,000+.

11. AI Red Team Specialist is a real job that 23% of cybersecurity organizations are actively hiring for right now (SANS 2026 Workforce Report). In your own words: what does an AI red teamer do, and why is it important?

12. After today's lab, which of these careers would you be most interested in exploring? Why? (Look back at the "Did You Know?" boxes for the options.)

Standards Alignment:

NICE Framework Work Roles: PD-WRL-001 (Defensive Cybersecurity) · PD-WRL-003 (Incident Response) · PD-WRL-006 (Threat Analysis) · PD-WRL-007 (Vulnerability Analysis) · DD-WRL-003 (Secure Software Development) · DD-WRL-005 (Software Security Assessment)

NICE TKS: K0106, K0005, K0119, K0070, S0078, T0260, T0175

OWASP: Top 10 for LLM Applications (2025) — LLM01, LLM02, LLM07

AP CSP: Big Idea 5 — Impact of Computing (5.5 Legal & Ethical Concerns, 5.6 Safe Computing)

PLTW Cybersecurity: Unit 2 (System Security), Unit 4 (Applied Cybersecurity)